

Acme Widgets LLC – Executive Summary

Prepared by	Ronin Security Consulting – CONFIDENTIAL
Engagement	acme-ext-2026q3
Client	Acme Widgets LLC
Tester	raven
Authorized by	J. Okafor, CTO
Testing window	2026-09-01 to 2026-09-30
Report generated	2026-09-09 23:46
Overall risk rating	Critical
Findings	9 total – 2 critical, 2 high, 1 medium, 2 low, 2 info

Prepared by Ronin Security Consulting under NDA. Client distribution only.

Overview

This report presents the results of an authorised offensive security assessment of Acme Widgets LLC's in-scope assets. The engagement's objective was to identify, from the perspective of a real attacker, weaknesses that could lead to unauthorised access, disclosure of sensitive data, or disruption of service – and to give management a clear, prioritised path to closing them.

Overall risk rating: Critical. Critical issues were identified that require immediate attention.

1. Scope & Methodology

1.1 Scope

In scope

- *.acme.example
- 203.0.113.0/28

Explicitly out of scope

- mail.acme.example

Testing window: 2026-09-01 to 2026-09-30.

Rules of engagement

External black-box. No DoS. No social engineering. Credential attacks only outside 09:00-17:00 local. Report any pre-existing compromise immediately.

1.2 Methodology

Testing followed an industry-standard workflow — reconnaissance, service enumeration, automated and manual vulnerability analysis, and controlled validation of exploitable issues — aligned with the PTES and the OWASP Testing Guide. Assessment activity used the tools listed below against the in-scope assets only. No denial-of-service testing was performed.

Tools used: subfinder, naabu, nmap, nuclei, feroxbuster, sqlmap, nikto.

2. Vulnerability Details — The Findings

The assessment identified **7 actionable issue(s)** across 2 in-scope target group(s). The table below summarises them by business risk; technical detail is in the Engineer-level report.

Risk	Count	What it means for the business
CRITICAL	2	Immediate threat — an attacker can take over systems or data now.

Risk	Count	What it means for the business
HIGH	2	Serious – likely exploited by a motivated attacker in a short timeframe.
MEDIUM	1	Meaningful – enables an attacker who has an initial foothold to progress.
LOW	2	Minor – hardening gaps that reduce defence-in-depth.

Headline issues

1. **SQL injection in GET parameter 'id' (MySQL)** – affects `https://app.acme.example/item?id=1`. CVSS 9.8. sqlmap confirmed boolean-based and UNION SQL injection via the id parameter; back-end is MySQL 8.0.
2. **Apache 2.4.49 Path Traversal / RCE (CVE-2021-42013)** – affects `https://app.acme.example`. CVSS 9.8. Apache httpd 2.4.49/2.4.50 unauthenticated path traversal; with mod_cgi enabled this is remote code execution.
3. **Open port 6379/tcp - Redis (internet-facing)** – affects `203.0.113.10:6379/tcp`. naabu found Redis exposed on the perimeter address
4. **nikto: Shellshock RCE may be possible via /cgi-bin/status.cgi** – affects `https://legacy.acme.example/cgi-bin/status.cgi`. nikto flagged a CGI endpoint potentially vulnerable to Shellshock (CVE-2014-6271).

3. Proof of Concept (PoC) & Attack Paths

The following plausible attack chains were identified. Each assumes a remote, unauthenticated attacker unless stated. Full reproduction steps are held in the Engineer-level report and are available to your technical team on request.

- **SQL injection in GET parameter 'id' (MySQL)**
(`https://app.acme.example/item?id=1`): Full DB read: dump customers + password hashes -> offline crack -> account takeover / admin. Stacked queries may allow RCE on the DB host.
- **Apache 2.4.49 Path Traversal / RCE (CVE-2021-42013)** (`https://app.acme.example`): Unauthenticated RCE as the web user -> pivot into 203.0.113.0/28. Public exploit exists.
- **Open port 6379/tcp - Redis (internet-facing)** (`203.0.113.10:6379/tcp`): Unauthenticated Redis -> read/alter cached data, write a webshell or SSH key via CONFIG SET, or gain RCE on the Redis host.

- **nikto: Shellshock RCE may be possible via /cgi-bin/status.cgi** (`https://legacy.acme.example/cgi-bin/status.cgi`): If confirmed, unauthenticated RCE on a legacy host - likely an unmonitored pivot point.
 - **Exposed Git repository at /.git/** (`https://app.acme.example/.git/HEAD`): Reconstruct source + committed secrets -> authenticated access / more vulns.
-

4. Remediation Recommendations

Recommended strategic priorities, in order:

1. **Stop the bleeding (0–30 days)**. Remediate all critical and high findings; 4 item(s). These are the issues an attacker would use first.
2. **Reduce attack surface (30–90 days)**. Address medium findings (1 item(s)) and remove exposed services that are not business-critical.
3. **Harden and verify (90–180 days)**. Close low-severity hygiene gaps, then commission a focused retest to confirm closure.
4. **Sustain**. Fold recurring checks (TLS config, security headers, exposed admin interfaces, patch currency) into a quarterly cadence.

Indicative timelines assume normal change-management capacity; critical items should be expedited.

Assurance & Limitations

This assessment reflects the state of the in-scope systems during the testing window only and is not a guarantee that no other vulnerabilities exist. Testing was time-boxed and non-destructive. A follow-up retest is recommended once remediation is complete to formally confirm closure.
